

Normativas y Estándares Externos

Banco Ther S.A



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Carrera: Ingeniería de Sistemas

Materia: Auditoria de Sistemas

Semestre: 9no Semestre

Integrantes:

García Aguirre Ignacio

Mattos Terán Fernanda

Pimentel Silva Jared

Quenta Ramos Ramiro

Valenzuela Rivera Mateo

Fecha: 3/3/2026

1 NORMA DE GESTIÓN DE IDENTIDADES Y ACCESOS

El Banco PYME Ther S.A. fundamenta su control de accesos en los principios de mínimo privilegio. La administración centralizada recae en la Subgerencia de Operaciones y Soporte, a través del Encargado de Gestión de Accesos. Todos los usuarios, tanto administrativos como operativos en agencias, cuentan con perfiles basados en roles. Para el acceso a sistemas críticos (Core Bancario, servidores o bases de datos) y conexiones remotas (VPN), es de carácter obligatorio el uso de Autenticación Multifactor. Las credenciales de personal desvinculado son revocadas en tiempo real mediante integración automatizada con el sistema de Recursos Humanos.

2 NORMA DE DESARROLLO SEGURO Y CERTIFICACIÓN DE SOFTWARE

Para garantizar la integridad de los canales digitales (Banca Web y App Móvil), se establece un ciclo de vida de desarrollo seguro. La Subgerencia de Aseguramiento de Calidad tiene la facultad de rechazar cualquier pase a producción. El Encargado de QA y el Encargado de Certificación deben aplicar pruebas rigurosas de estrés y análisis de vulnerabilidades (alineadas a OWASP Top 10) antes de liberar cualquier actualización o nueva API desarrollada por la Subgerencia de Desarrollo de Sistemas. Queda estrictamente prohibido que los desarrolladores tengan acceso directo al entorno de producción.

3 NORMA DE CONTINUIDAD, RESILIENCIA Y RESPALDOS

La protección de la información se rige bajo la estrategia de respaldo 3-2-1, administrada por el Operador de Backup y Continuidad. Todos los datos transaccionales alojados en la SAN de 150TB cuentan con copias incrementales diarias y respaldos completos semanales, cifrados con AES-256. El banco

establece un RTO (Tiempo Objetivo de Recuperación) menor a 4 horas y un RPO (Punto Objetivo de Recuperación) de 1 hora para servicios críticos. Se exige la realización de simulacros de recuperación ante desastres de forma semestral para garantizar la resiliencia del clúster de alta disponibilidad.

4 NORMA DE ARQUITECTURA CENTRALIZADA Y SEGURIDAD PERIMETRAL

Toda comunicación entre las sucursales y agencias con el Core Bancario debe converger obligatoriamente en el nodo central mediante una topología Estrella. La Subgerencia de Infraestructura y Telecomunicaciones, mediante el Administrador de Redes, es responsable de mantener firewalls de nueva generación y un Web Application Firewall que inspeccione todo el tráfico entrante. Las reglas de firewall operan por defecto en modo "denegar todo", permitiendo únicamente el tráfico explícitamente autorizado.

5 NORMA DE GESTIÓN, INTEGRACIÓN Y PRIVACIDAD DE DATOS

El manejo de los datos financieros y analíticos está bajo el control estricto de la Unidad de Administración de Datos. Para la generación de reportes regulatorios exigidos por la ASFI o tableros de inteligencia de negocios (BI), el Analista de Integración de Datos debe utilizar herramientas automatizadas (ETL) que extraigan la información de réplicas de solo lectura, prohibiendo consultas pesadas directas sobre la base de datos de producción para no afectar el rendimiento del Core. Toda la información financiera y de tarjetas debe permanecer cifrada.

6 NORMA DE MONITOREO DE SEGURIDAD Y RESPUESTA A INCIDENTES

La entidad mantiene una vigilancia permanente sobre sus activos mediante agentes de protección de endpoints (EDR) instalados en todas las estaciones de

trabajo y servidores. El área independiente de Seguridad de la Información supervisa la correlación de eventos, como movimientos laterales sospechosos o ataques de día cero. Los registros de auditoría (logs) de los sistemas críticos no pueden ser alterados ni borrados por los administradores de TI, y se conservan por un mínimo de 12 meses para garantizar la trazabilidad forense.

7 ESTÁNDARES DE CONTROL Y NORMATIVA EXTERNA

- NIST: Se utiliza como la principal referencia técnica para estructurar el gobierno de ciberseguridad, organizando los controles a través de funciones clave (Identificar, Proteger, Detectar, Responder y Recuperar). Ayuda a integrar el riesgo tecnológico directamente con la estrategia de protección del banco.
- ITIL: Marco de mejores prácticas implementado en la Subgerencia de Operaciones y Soporte para estandarizar la atención de la Mesa de Ayuda. Está enfocado en la gestión eficiente de incidentes, peticiones de servicio y cambios controlados, asegurando la continuidad de los servicios diarios.
- OWASP: Estándar rector de seguridad de software aplicado por la Subgerencia de Aseguramiento de Calidad y la Subgerencia de Desarrollo de Sistemas. Se utilizan guías como el OWASP Top 10 para identificar, testear y mitigar vulnerabilidades críticas como inyecciones de código antes de que la Banca Web o la App Móvil pasen a producción.
- PCI DSS: Normativa de cumplimiento estricto aplicada de forma focalizada al entorno de datos del titular de tarjeta. Exige a la Subgerencia de Infraestructura y Telecomunicaciones mantener la red segmentada,

cifrado fuerte y firewalls para proteger las transacciones electrónicas de los clientes contra el fraude.